

Taller 1 — Introducción a ciberseguridad I

Sesión 1 • 14 de agosto de 2026 • Profesor: Ricardo Duitama

Sergio Andrés Caceres Díaz, Over Haider Castrillón Valencia, Michael Andrés Cifuentes Mirke

Nota de borrador cómo usar esta plantilla

Cada pregunta del enunciado está transcrita como \pregunta seguida de un entorno respuesta vacío. Escribe dentro del entorno; mientras esté vacío aparece la caja naranja y el .log deja un warning «Respuesta pendiente». En los bloques de selección múltiple marca tu elección cambiando \opcion por \opcion* (admite varias, el enunciado dice «1 o más respuestas válidas»). Estas notas naranjas desaparecen con make ws-01 FINAL=1.

1. Confidencialidad

Caso: Fuga de datos del portal Ashley Madison (2015)

Investigar sobre el caso de fuga de datos del portal Ashley Madison del 2015.

Fuentes

- https://en.wikipedia.org/wiki/Ashley_Madison_data_breach
- <https://digitalguardian.com/blog/timeline-ashley-madison-hack>
- <https://www.wired.com/2015/08/happened-hackers-posted-stolen-ashley-madison-data/>
- Otros disponibles en la web.

Q1. ¿Qué tipos de datos fueron expuestos?

Pendiente por responder

Q2. ¿Cómo se logró la exfiltración de datos?

Pendiente por responder

Q3. ¿Qué mecanismo(s) pudo haberse implementado para evitar la fuga de datos?

Pendiente por responder

Validación de entendimiento del caso

Q4. En el caso de Ashley Madison estudiado previamente puede verse la confidencialidad como (1 o más respuestas válidas):

- a. Un atributo de los datos el cual fue afectado severamente debido a la no existencia de controles de seguridad adecuados.
- b. Un atributo de los datos que hay que proteger sobre todo cuando se trata de información personal.
- c. Un atributo de los datos que puede ser un diferencial en el momento de selección de una empresa proveedora de servicios por parte de un cliente.
- d. Un atributo de los datos que se refiere a que estos no sean vistos por alguien no autorizado.

Nota de borrador verificar contra las diapositivas

El enunciado de `notes/ws-01.md` viene de un PDF con OCR: las opciones *b* y *c* llegaron fusionadas en una sola línea (`ws-01.md:18-20`). El corte de arriba se reconstruyó por sentido; coteja el orden a-d contra la diapositiva original antes de entregar. Marca tu(s) elección(es) con `\opcion*`.

2. Integridad

Caso: Intrusión y modificación no autorizada de productos de AVAST (CCleaner)

Leer el caso de intrusión y modificación no autorizada de productos de AVAST.

Fuentes

- <https://www.forbes.com/sites/thomasbrewster/2019/10/21/avast-hacked-again-as-spies-steal-its-passwords/>
- <https://thehackernews.com/2018/04/ccleaner-malware-attack.html>
- Otros disponibles en la web.

Q5. ¿Cuál era el objetivo final del atacante?

Pendiente por responder

Q6. ¿Cómo se logró la modificación de los datos o servicios?

Pendiente por responder

Q7. ¿Qué mecanismo(s) pudo haberse implementado para evitar la intrusión y la modificación no autorizada?

Pendiente por responder

Validación de entendimiento del caso

Q8. En el caso de CCleaner estudiado previamente, ¿cuál fue el objetivo más probable del atacante? (1 o más respuestas válidas):

- a. Implantar código malicioso dentro del código fuente del aplicativo CCleaner con el objetivo de que cada persona que descargue CCleaner también descargue el código malicioso y se infecte.

- b. Eliminar el código fuente de CCleaner para causar un impacto operativo a Avast.
- c. Ingresar de manera no autorizada a la red de Avast para copiar secretos comerciales.
- d. Comprobar que una empresa de seguridad no está exenta de tener vulnerabilidades.

Nota de borrador verificar contra las diapositivas

Igual que en la sección anterior, las opciones *b*, *c* y *d* llegaron fusionadas por el OCR (ws-01.md:44-46); el corte se reconstruyó por sentido. Coteja contra la diapositiva original antes de entregar.

3. Disponibilidad

Caso: Intrusión y eliminación no autorizada de datos bancarios (Corea del Sur, Shinhan Bank)

Leer el caso de intrusión y eliminación no autorizada de datos bancarios.

Fuentes

- <https://www.seeker.com/massive-data-deleting-attack-hits-south-korea-1767326593.html>
- <https://www.nbcnews.com/id/wbna51256632>
- <https://www.darkreading.com/cyberattacks-data-breaches/south-korean-banks-lose-data-in-malware-attack>
- Otros disponibles en la web.

Q9. ¿Cuál era el objetivo final del atacante?

Pendiente por responder

Q10. ¿Cómo se logró la eliminación de los datos o servicios?

Pendiente por responder

Q11. ¿Qué mecanismo(s) pudo haberse implementado para evitar la eliminación no autorizada de datos?

Pendiente por responder

Validación de entendimiento del caso

Q12. En el caso de Shinhan Bank estudiado previamente, ¿cuál fue el vector de entrada más probable utilizado por el atacante? (1 o más respuestas válidas):

- a. Explotación de una vulnerabilidad en el portal web de Shinhan Bank que permitió afectar el sistema operativo de las máquinas corporativas.
- b. Equipos corporativos que hacían parte de una botnet y a través de los cuales fue posible la eliminación de archivos de sistema operativo.
- c. Inserción de una USB infectada por parte de uno de los empleados, a través de la cual se realizó la implantación de un malware de corrupción del sistema operativo.

4. Autenticación, Autorización y Accounting (AAA)

Los 3 atributos clave

Atributo	Definición (slides)	Pregunta que responde
Autenticación	Validación de la identidad de un usuario o proceso.	<i>Who is the user and does he have valid credentials?</i>
Autorización	Validación de los permisos otorgados a un usuario o proceso.	<i>What can the user do and does he have the authority?</i>
Accounting	Registro de la actividad de un usuario o proceso.	<i>What did the user do and is it being recorded?</i>

La *e-authentication* es el proceso de establecer confianza en las identidades de usuario de forma electrónica dentro de un sistema de información. La gestión de autenticadores (*authenticator management*) cubre los procesos y procedimientos de emisión y revocación de autenticadores, y aplica tanto a hardware como a software: contraseñas, *tokens*, biometría, certificados de infraestructura de clave pública (PKI), tarjetas de acceso, entre otros.

Nota de borrador ampliar si hace falta

Esta tabla resume las slides 10–28. Si el profesor pide desarrollo propio del marco AAA, amplía aquí antes de pasar a las preguntas del DBIR.

5. Verizon DBIR 2025

Caso: 2025 Verizon Data Breach Investigation Report

Obtener una copia del *2025 Verizon Data Breach Investigation Report* (ver informe en e-Aulas URo-sario) y, tras haber entendido los conceptos de Autenticación, Autorización y Accounting de las slides 10–28, responder las siguientes preguntas.

Fuentes

- <https://www.verizon.com/business/resources/T6eb/reports/2025-dbir-data-breach-investigations-report.pdf>

Q13. En la sección IV, identifica la ficha para el sector de la industria en el que trabajas. Identificar los patrones de incidentes más comunes, actores, motivaciones, tipos de datos comprometidos y *top* de controles de seguridad. Realiza un resumen para tu sector.

Pendiente por responder

Q14. ¿Cómo puede ayudar la autenticación, autorización y accounting a incrementar la seguridad en el sector escogido previamente?

Pendiente por responder

Q15. ¿Cuál de los 12 sectores no tiene control de acceso como parte de su *Top IG1 Protective Controls*?

Pendiente por responder